

1(4)

Postal Address:

Box 8114

104 20 Stockholm

Website:

www.imy.se

Email:

imy@imy.se

Phone:

08-657 61 00

Establishment of Requirements for

Accreditation of Monitoring Bodies

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (IMY) establishes, pursuant to Article 41 of the General Data Protection Regulation,¹ the requirements that bodies tasked with monitoring compliance with codes of conduct must meet in order to be accredited, in accordance with Article 41.2 of the General Data Protection Regulation. The requirements are outlined in the appendix to this decision.

Case Summary

According to Article 40.1 of the General Data Protection Regulation, supervisory authorities “shall encourage the establishment of codes of conduct intended to contribute to the correct application of the General Data Protection Regulation, taking into account the specificities of the various sectors in which processing takes place, and the specific needs of micro, small, and medium-sized enterprises.”

A prerequisite for codes of conduct to be developed by Swedish associations and bodies representing categories of data controllers or processors is that IMY establishes the requirements that shall apply for the accreditation of the bodies – so-called monitoring bodies – that will oversee compliance with the provisions of the code of conduct by its members.²

Against this background, IMY prepared a draft of the requirements for the accreditation of monitoring bodies, in accordance with the guidelines of the European Data Protection Board (EDPB) (1/2019).³ The draft was submitted, pursuant to Article 41.3 of the General Data Protection Regulation, to the EDPB for an opinion, in accordance with Article 64.3 of the General Data Protection Regulation.⁴

The EDPB issued its opinion on July 11, 2023, and recommended that IMY in the accreditation requirements:

☐ generally avoid the term "should" and instead impose prescriptive requirements by using the term "shall,"

☐ clarify that internal monitoring bodies shall not be established within the members of the code of conduct,

¹ Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing

Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, p. 1).

² Article 41.1 of the General Data Protection Regulation.

³ Guidelines 1/2019 on codes of conduct and monitoring bodies pursuant to Regulation (EU) 2016/679 (04.06.2019).

Available: [https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-12019-codes-conduct-and-](https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-12019-codes-conduct-and-monitoring-bodies-0_sv)

[monitoring-bodies-0_sv](https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-12019-codes-conduct-and-monitoring-bodies-0_sv) (10.08.2023). See in particular section 12.

⁴ Dnr IMY-2022-6945-1; IMI case no. 506369.

Case Number:

IMY-2022-6945

Date:

2023-09-07

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Date: 2023-09-07

2(4)

- ☐ replace the term "may" with "shall" in section 1.2.1 of the draft,
- ☐ clarify in section 5.7 of the draft that information shall not only be provided to IMY, but to all relevant supervisory authorities,
- ☐ clarify in section 6 that effective communication shall not only occur with IMY, but with all relevant supervisory authorities, and
- ☐ impose requirements for effective monitoring when monitoring bodies engage subcontractors in the performance of their tasks.⁵

In light of the above recommendations, IMY amended the requirements and submitted a revised draft decision to the EDPB, pursuant to Article 64.7 of the General Data Protection Regulation.⁶ The EDPB confirmed receipt of the revised draft decision and concluded the matter on August 11, 2023.⁷

Justification of the Decision

Codes of conduct are a useful tool for data controllers and processors when they need to demonstrate compliance with the requirements of the General Data Protection Regulation.⁸ Not least, codes of conduct can be used to establish what requirements and protective measures are appropriate to apply in personal data processing within certain sectors or industries.⁹ In this way, industry organizations and other interest groups can become involved in the development of more detailed guidance on how the General Data Protection Regulation should be interpreted for personal data processing that is specific or commonly occurring within a certain sector or industry.¹⁰ By having codes of conduct approved by the competent supervisory authority¹¹ or – in the case of cross-border codes of conduct – the EDPB,¹² reliability in compliance with the provisions of the General Data Protection Regulation that the code of conduct encompasses is ensured, as long as the code of conduct is followed.

For a code of conduct to be approved by the competent supervisory authority or EDPB, it must contain mechanisms for monitoring by an independent and competent monitoring body.¹³ The monitoring body shall continuously monitor the application of the code of conduct¹⁴ and shall also have the authority to take measures,

⁵ Opinion 11/2023 on the draft decision of the competent supervisory authority of Sweden regarding the approval of the requirements for accreditation of a code of conduct monitoring body pursuant to article 41 GDPR (11.07.2023) p.

³⁵⁻³⁸. Available: https://edpb.europa.eu/system/files/2023-07/edpb_opinion_202311_se_sa_accreditation_requirements_for_monitoring_bodies_en.pdf (10.08.2023).

⁶ Dnr IMY-2022-6945-5; IMI case no. 542337.

⁷ Dnr IMY-2022-6945-6.

⁸ Recital 77 and Article 24.3 of the General Data Protection Regulation.

⁹ Guidelines 1/2019, p. 14–15.

¹⁰ Guidelines 1/2019, p. 13.

¹¹ Article 40.5 of the General Data Protection Regulation.

¹² Article 40.7 of the General Data Protection Regulation.

¹³ Article 40.4 of the General Data Protection Regulation. It should be noted that codes of conduct developed within the public sector do not need to be monitored by a monitoring body, according to Article 41.6 of the

General Data Protection

Regulation.

14 Article 41.2 b of the General Data Protection Regulation.

Swedish Authority for Privacy Protection

Reference Number: IMY-2022-6945

Date: 2023-09-07

3(4)

such as suspension or exclusion, against data controllers or processors who violate the provisions of the code.¹⁵

The monitoring body's oversight does not replace the powers of supervisory authorities to take action in cases of suspected violations of the General Data Protection Regulation (GDPR),¹⁶ but serves as a useful complementary tool to promote compliance with the GDPR, and the monitoring body provides an additional channel for data subjects to turn to if they have complaints regarding the processing of personal data by members of the code of conduct.¹⁷

In order to carry out oversight of a code of conduct, a monitoring body must be accredited for this purpose by a competent supervisory authority, in accordance with the requirements set by the supervisory authority.¹⁸ The requirements must ensure that a monitoring body:

- i.
demonstrates its independence and expertise in relation to the purpose of the code of conduct in a manner that the competent supervisory authority finds satisfactory,
- ii.
has established procedures through which it can assess the suitability of the relevant data controllers and processors to apply the code of conduct, monitor their compliance with its provisions, and regularly review how the code is functioning,
- iii.
has established procedures and structures for handling complaints about violations of the code of conduct or the manner in which the code has been applied, or is being applied, by a data controller or a data processor, and to make these procedures and structures visible to data subjects and the public, and
- iv.
in a manner that the competent supervisory authority finds satisfactory, has demonstrated that its tasks and mission do not lead to a conflict of interest.¹⁹

As outlined above, it is a prerequisite that monitoring bodies can apply to IMY for accreditation in order for codes of conduct to be developed by Swedish associations and bodies representing categories of data controllers or processors under IMY's supervisory authority.

Against this background and in order to encourage the development of codes of conduct, it is essential that IMY establishes requirements for the accreditation of monitoring bodies.²⁰

As mentioned above, IMY submitted a draft of the accreditation requirements to the EDPB for review, and as a result of the EDPB's opinion, the requirements have also been amended in certain respects.²¹

The accreditation requirements set forth in the annex establish requirements in the following areas:

15 Article 41.4 of the General Data Protection Regulation.

16 Article 41.4 of the General Data Protection Regulation.

17 Article 41.2 c of the General Data Protection Regulation.

18 Article 41.1 of the General Data Protection Regulation.

19 Article 41.2 of the General Data Protection Regulation.

20 The accreditation requirements are outlined in the annex to this decision.

21 For more information, see: reference number IMY-2022-6945-5; IMI case number 542337.

Swedish Authority for Privacy Protection

Reference Number: IMY-2022-6945

Date: 2023-09-07

4(4)

- ☐ independence,
- ☐ conflict of interest,
- ☐ expertise,
- ☐ procedures and structures,
- ☐ handling of complaints,
- ☐ communication with the supervisory authority,
- ☐ mechanisms for reviewing the code of conduct,
- ☐ legal status, and
- ☐ subcontractors.²²

IMY assesses that the accreditation requirements have been formulated in accordance with Article 41.2 of the General Data Protection Regulation and EDPB Guidelines 1/2019. The requirements for the accreditation of monitoring bodies set forth in the annex shall therefore be established. This decision has been made by Acting Director General Karin Lönnheden after presentation by lawyer Cedric Voss. The final processing has also involved Legal Director David Törngren.

Karin Lönnheden, 2023-09-07

(This is an electronic signature)

Annex

Requirements for the accreditation of monitoring bodies

22 Guidelines 1/2019, section 12.

Swedish Authority for Privacy Protection

Reference Number: IMY-2022-6945

Date: 2023-09-07

1(27)

Annex - Requirements for the accreditation of monitoring bodies

Table of Contents

Introduction	2
Application Requirements	3
Duration of Accreditation	4
1	
Independence	5
1.1	
Legal Procedures and Decision-Making Procedures	5
1.2	
Financial Resources	7
1.3	
Organization's Resources and Structure	8
1.4	
Accountability	9
2	
Conflict of Interest	11
3	
Expertise	13

4	
Established Procedures and Structures	15
5	
Open Handling of Complaints	18
6	
Communication with IMY	20
7	
Mechanisms for Reviewing Codes	22
8	
Legal Status	24
9	
Subcontractors	26

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Monitoring Bodies

2(27)

Introduction

In accordance with Article 41.4 of the General Data Protection Regulation (GDPR), national and cross-border codes of conduct must be monitored by a monitoring body that is accredited by the competent supervisory authority. In Sweden, the competent supervisory authority is the Swedish Authority for Privacy Protection (Integritetsskyddsmyndigheten, IMY). According to Article 41.6 of the GDPR, as clarified in the guidelines of the European Data Protection Board (EDPB), the requirement for an accredited monitoring body does not apply to processing carried out by public authorities and bodies.

The monitoring body can be either external or internal to the owner of the code of conduct. An internal monitoring body can be an internal department of the code owner or a temporary internal committee. Article 41.2 of the GDPR establishes a number of requirements that the proposed monitoring body must meet in order to obtain accreditation. A monitoring body shall:

- ☐ demonstrate independence and expertise regarding the content of the code of conduct,
- ☐ demonstrate established procedures that enable relevant data controllers and data processors to apply the code of conduct, monitor compliance with the code, and regularly review the functioning of the code,
- ☐ demonstrate established procedures and structures for handling complaints about violations of the code of conduct, as well as how the code has been implemented, or is being implemented, by a data controller or a data processor, and how these procedures and structures are open to data subjects and the public, and
- ☐ satisfactorily demonstrate to the competent supervisory authority that its tasks and obligations do not lead to a conflict of interest.

The EDPB's guidelines in this area provide important practical guidance and interpretative assistance in the application of Article 41.2 of the GDPR. In Section 12 of the EDPB's guidelines, the accreditation requirements in Article 41.2 of the GDPR are categorized into the following eight categories:

- ☐ Independence
- ☐ Conflict of Interest

23 Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (EUT L 119, 4.5.2016, p. 1).

24 Guidelines 1/2019 on codes of conduct and monitoring bodies under Regulation (EU) 2016/679 (04.06.2019). Available: https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-1-2019-codes-conduct-and-monitoring-bodies-0_sv (10.08.2023). See in particular Section 12.

25 Article 41.6 of the GDPR.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Monitoring Bodies

3(27)

- ☐ Expertise
- ☐ Established Procedures and Structures
- ☐ Transparency in Handling Complaints
- ☐ Communication with the Competent Supervisory Authority
- ☐ Review Mechanisms
- ☐ Legal Status

The requirements set out in this document are based on the requirements in Article 41.2 of the GDPR and the requirements specified in Section 12 of the EDPB's guidelines. The organization of the requirements follows the structure of the guidelines.

Application Requirements

The accreditation of a monitoring body should not hinder the development of codes of conduct. The assessment of the application for accreditation as a monitoring body should therefore take into account the specific characteristics of each sector's processing and be as flexible as possible, while respecting the legal framework prescribed in the GDPR, the EDPB's guidelines, and relevant opinions from the EDPB.

Applicants must meet all accreditation requirements set out in this document to be accredited by IMY. The requirements apply to monitoring bodies, whether they are internal or external monitoring bodies, unless otherwise specified.

Accreditation as a monitoring body is only possible in relation to the subject of one or more specific codes of conduct, in accordance with Article 41.1 of the GDPR.

The application for accreditation must be submitted in written form to IMY. The application must be submitted in Swedish. The application must include evidence that the requirements have been met by submitting relevant documents, certificates, etc., in accordance with these requirements.

The application must at least contain the following information:

1. Information identifying the applicant, e.g., identification number such as organization number.
2. The applicant's place of establishment or registered office, which in both cases must be located within the European Economic Area (EEA).
3. Contact details to be used for all communication regarding the accreditation application.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

4(27)

4.

Specification of the type of supervisory body (i.e., whether it is internal or external).

5.

Specification of the code of conduct for which accreditation is sought.

6.

Scope of the code of conduct (including whether it is national or cross-border).

7.

Supporting documents.

Detailed documentation requirements are included in each of the accreditation requirements below.

Duration of Accreditation

A decision on accreditation is valid until further notice.

IMY reserves the right to conduct reviews of the supervisory body to ensure that the body continues to meet the requirements for accreditation. Such a review may be initiated, among other reasons, due to changes in the code of conduct, legal amendments affecting the supervisory body's ability to perform its supervisory functions, significant changes in the supervisory body, or if the supervisory body fails to fulfill its supervisory functions. In the case of significant changes to the supervisory body's ability to operate independently and effectively, a review will always be conducted.

The supervisory body will retain its accreditation status, except if the outcome of a review shows that

the requirements for accreditation are no longer met. If the requirements for accreditation are no longer met, IMY reserves the right to revoke the accreditation.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

5(27)

1 Independence

According to Article 41.2 a of the Data Protection Regulation, the supervisory body must demonstrate its independence in relation to the content of the code of conduct.

The independence of a supervisory body can be understood as a series of formal rules and procedures for the appointment, mandate, and operations of the supervisory body. These rules and procedures will enable the supervisory body to monitor compliance with a code of conduct with complete independence, without direct or indirect influence, and without being subject to any form of pressure that could affect its decisions.

A supervisory body must not be able to receive instructions regarding the performance of its duties from members of the code of conduct, the profession, the industry, or sector to which the code of conduct applies, or from the owners of the code of conduct. Therefore, rules and procedures must be established to ensure that the supervisory body acts independently and without pressure. When the supervisory body is internal, there must be a particular focus on the supervisory body's ability to act independently.

Independence must be demonstrated in four main areas:

- ☐ Legal procedures and decision-making processes
- ☐ Financial resources
- ☐ Organizational resources and structure
- ☐ Responsibility / appointment of members / staff

The requirements for these areas are specified below.

Legal Procedures and Decision-Making Processes

1.1.1 The supervisory body must be appropriately independent in relation to the members of the code of conduct, the profession, the industry, or sector to which the code of conduct applies, and the owners of the code of conduct, particularly regarding any legal and financial ties that may exist between the supervisory body and the owners or members of the code of conduct. The supervisory body shall implement an appropriate decision-making process to ensure its independence.

1.1.2 The supervisory body must act independently in choosing and applying its measures and sanctions against a data controller or a data processor that adheres to the code of conduct.

1.1.3 The mandate of the supervisory body and its termination must be regulated in a way that prevents excessive dependence on a renewal or fear of losing the appointment, to an extent that negatively impacts the supervisory body's independence in performing its oversight.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

6(27)

Guidance

The supervisory body should be appointed to oversee the code of conduct for a period of at least three years.

1.1.4 The supervisory body must not provide any services to the members or owners of the code of conduct that could negatively impact the body's independence.

Guidance

Permissible services may relate to the development or improvement of the code of conduct or provide guidance on the implementation of the code of conduct.

1.1.5 The supervisory body shall present evidence during the application process that the body and its staff can act independently and without external influence.

Guidance

The independence of the supervisory body regarding legal procedures and decision-making processes can be substantiated through:

- a) Formal rules for appointment.
- b) Job descriptions and work descriptions.
- c) Documented recruitment processes for staff.
- d) Information about individuals in the supervisory body who are authorized to make decisions, demonstrating that there are no conflicting interests with the organizations to be supervised.
- e) A description of the owners of the code of conduct.
- f) Information about the duration or termination of the supervisory body.
- g) Evaluation and management of risks concerning independence.
- h) Documents that substantiate the business, financial, contractual, or other relationships between the supervisory body and the association or organization submitting the code of conduct, as well as the members of the code of conduct.
- i) For internal supervisory bodies: a description of the committees, separate departments, or staff that may be involved in the supervisory body,

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

7(27)

future information barriers between the owners of the code of conduct and the supervisory body, as well as separate reporting structures.

Financial Resources

1.2.1 The supervisory body must be financially independent in an appropriate manner. Financial independence shall be demonstrated by showing full independence from the entity that allocates budget funds and other resources to the supervisory body, particularly in cases where the supervisory body is internal.

1.2.2 The supervisory body must be able to manage its budget and resources independently without any form of influence from the owners and members of the code of conduct. A specific separate budget shall be allocated to the supervisory body by the owners of the code of conduct to ensure that the funding of the body's activities is sustainable over time.

Guidance

The funding of the supervisory body should be guaranteed for a period of at least two years.

1.2.3 The supervisory body shall be able to demonstrate that it has the financial stability and resources required to carry out its supervisory activities effectively and sustainably. Such resources must be secured in the long term, and the loss of one or more funding sources should not affect the independence of the supervisory body.

1.2.4 The manner in which the supervisory body receives financial support (e.g., a fee paid by the members of the code of conduct) must not negatively impact the body's independence. The supervisory body shall demonstrate to IMY during the application process how it receives financial support for its supervisory role and explain how this does not jeopardize the body's independence.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

8(27)

Guidance

Financial independence can be substantiated with documentation of income sources, past or projected revenues and expenses, as well as information on relevant assets or liabilities.

The supervisory body will not be considered financially independent if, for example, the rules for its financial support allow a member of the code of conduct under investigation to stop its financial contributions to the body to avoid a potential sanction from the supervisory body.

1.2.5 In ensuring financial independence, the supervisory body shall take into account the number and size of the members of the code of conduct (as supervised organizations), the nature and scope of

their processing (the subject of the code of conduct), and the risks associated with the processing, including the complexity or degree of risk of the relevant data processing.

Organization's Resources and Structure

1.3.1 The supervisory body must be organized in such a way that it can act independently of the owners and members of the code of conduct when the body performs its tasks and exercises its powers.

1.3.2 The supervisory body must have the staffing and technical resources necessary to perform its tasks effectively.

1.3.3 The supervisory body shall consist of a sufficient and proportionate number of adequately qualified staff so that it can perform the supervisory functions in a manner that reflects the relevant sector and the nature, scope, complexity, and risks of the personal data processing covered by the code of conduct.

Guidance

To ensure that the supervisory body is adequately staffed, specific procedures and salary structures should be established that enable the supervisory body to retain its employees over time.

As a general rule, the supervisory body should apply employment forms that ensure sufficient staffing.

1.3.4 The supervisory body shall be accountable and have the authority to make decisions regarding the supervisory activities.

1.3.5 When the supervisory body is internal, there must be separate personnel and management to ensure accountability and functionality from other parts of the organization (i.e., the owners of the code of conduct). The internal supervisory body must be able to act free from instructions and shall be protected from all forms of sanctions or disruptions (direct or indirect) resulting from the fulfillment of its task.

1.3.6 The supervisory body must not be established within the organization of any of the members of the code of conduct.

Guidance

Points 1.3.5 and 1.3.6 can be achieved through the use of effective organizational barriers and information barriers as well as separate structures for reporting management, or through any other logical distinction between the supervisory body and the owners or members of the code of conduct.

1.3.7 The supervisory body shall demonstrate its organizational independence to IMY during the application process.

Guidance

Evidence of the supervisory body's organizational independence can be provided through:

- a) Identification of risks to its organizational independence and how it will remove or minimize such risks and the use of an appropriate mechanism to ensure impartiality.
- b) For internal supervisory bodies, documentation regarding the establishment of the supervisory body and information about its relationship with the organization that the supervisory body is part of (i.e., the owners of the code of conduct).

Accountability

1.4.1 The supervisory body must be able to demonstrate that it is accountable for its decisions and actions to be considered independent.

Guidance

The accountability of the supervisory body can be achieved by establishing a framework for roles, decision-making, and reporting procedures to ensure independence between the supervisory body and the owners or members of the code of conduct, and by establishing strategies to increase staff awareness of governance structures and applicable procedures.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

10(27)

1.4.2 Decisions made by the supervisory body in connection with its functions shall not be approved by any other organization, including the owner of the code of conduct.

1.4.3 The supervisory body shall provide evidence to IMY of its impartiality regarding accountability

during the application process.

Guidance

Evidence of impartiality regarding accountability may include, but is not limited to:

- a) Job descriptions.
- b) Management reports and training of staff (i.e., guidelines to increase staff awareness of governance structures and applicable procedures).

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

11(27)

2 Conflict of Interest

According to Article 41.2 d of the Data Protection Regulation, the supervisory body must demonstrate that its tasks and obligations do not lead to a conflict of interest.

It must therefore be shown that the supervisory body and its staff will refrain from any actions that are incompatible with its tasks and that safeguards are implemented to ensure that the body will not engage in incompatible activities.

The requirements below aim to ensure that the supervisory body can carry out its supervisory activities impartially, identify situations that may create a conflict of interest, and take measures to avoid such situations.

The supervisory body shall have its own staff appointed by the supervisory body or another body that is independent of the code of conduct and its members. The staff shall be solely accountable to the supervisory body.

Guidance

An example of staff selected by a body that is independent of the code of conduct is personnel recruited by an independent external company that provides recruitment and personnel services.

The supervisory body must remain free from external influence, whether direct or indirect, and must neither request nor accept instructions from any person, organization, or association.

The supervisory body must be protected from all kinds of sanctions or interference (direct or indirect) by the owner of the code of conduct, other relevant bodies, or members of the code of conduct, as a result of fulfilling the body's tasks.

The supervisory body must identify situations that may create a conflict of interest (due to its staff, organization, procedures, etc.) and implement internal procedures to manage the effects of situations that may create a conflict of interest. Such procedures will vary depending on the code of conduct. If actual or potential conflicts of interest are identified, appropriate measures must be taken to ensure the independence of the supervisory body.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

12(27)

Guidance

An example of a conflict of interest may be if the supervisory body's staff investigate complaints against an organization they work for. Ownership, governance, management, staff, shared resources, finance, contracts, outsourcing, training, marketing, and payment of sales commissions are other potential sources of conflicts of interest.

Examples of what does not constitute a conflict of interest:

Provision of services that are purely administrative, organizational support, or other similar support activities.

The supervisory body's staff shall be obligated to report all situations that may create a conflict of interest. In cases of conflicts of interest among staff, the individuals involved must declare their interests, and the work shall be redistributed.

The supervisory body shall continuously identify and eliminate risks to its impartiality.

The supervisory body must train its staff on situations that may create a conflict of interest and the

internal procedures applicable in these situations.

The supervisory body shall provide information about its management of conflicts of interest to IMY during the application process. The supervisory body's risk management method (according to the requirements in section 2.4) and associated procedures shall be included in the application.

Swedish Data Protection Authority

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

13(27)

3 Expertise

According to Article 41.2 a of the Data Protection Regulation, the supervisory body must demonstrate its expertise regarding the scope of the code of conduct.

The supervisory body must possess the expertise required to effectively perform its role.

All codes of conduct with supervisory bodies must describe the level of expertise required for the supervisory body of the code so that the supervisory activities can be carried out effectively. The expertise of the supervisory body must be assessed in accordance with the relevant code of conduct. Requirements specific to a code of conduct will depend on factors such as the particular sector, the area of personal data processing, the various interests involved, and the risks associated with the personal data processing covered by the code of conduct. These requirements specific to a code of conduct will be considered part of the accreditation. The supervisory body must always meet the requirements set out below. Additional or specific requirements for expertise need only be met if the code of conduct prescribes such requirements.

IMY will assess whether the supervisory body meets the expertise requirements based on the supervisory body as a whole. Therefore, the qualifications and experience of all personnel will be included in the assessment.

The supervisory body must have in-depth knowledge and experience regarding data protection legislation (including relevant technical knowledge), the sector, and specific personal data processing within the framework of the code of conduct.

The supervisory body must ensure that personnel making decisions on behalf of the supervisory body have appropriate sector-specific and data protection expertise.

The supervisory body must ensure that personnel performing supervisory functions have appropriate sector-specific and data protection expertise, operational experience, as well as training and qualifications in auditing, monitoring, or quality assurance.

The supervisory body must demonstrate to IMY during the application process that it not only meets the requirements in sections 3.1–2 above but also the relevant competence requirements according to the code of conduct.

Swedish Data Protection Authority

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

14(27)

Guidance

Evidence of the supervisory body's expertise may include, but is not limited to, the following:

- a) Documented previous experience of the supervisory body acting as a supervisor of a specific sector.
- b) Description of the qualifications and previous experience of the personnel employed by the supervisory body.
- c) Documentation of training of personnel to monitor compliance with the code of conduct, such as certifications and diplomas.
- d) Documentation concerning the personnel's expertise in data protection, e.g., training and data protection certificates.

Swedish Data Protection Authority

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

15(27)

4 Established Procedures and Structures

According to Article 41.2 a of the Data Protection Regulation, the supervisory body must demonstrate that it has established procedures that enable the body to assess whether data controllers and data processors are entitled to apply the code of conduct, monitor their compliance with the provisions of the code, and regularly review its function.

The supervisory body must have an operationally feasible monitoring mechanism.

The requirements below aim to ensure that the supervisory body's monitoring process is effective in terms of resources and procedures.

The supervisory body must be provided with the financial stability and resources necessary for it to perform its tasks effectively and the procedures required for the code of conduct to function over time.

The resources must be proportional to the expected number of members of the code of conduct and the size of their organizations, as well as the complexity and degree of risk associated with the relevant personal data processing and the complaints that the supervisory body is expected to receive.

The supervisory body must establish procedures to assess whether data controllers and data processors are entitled to register and comply with the code of conduct. Such procedures must include an assessment of whether the relevant processing of personal data falls within the scope of the code of conduct.

The supervisory body must also provide evidence of initial, specific, and regular procedures for monitoring members' compliance within a clear timeframe and verify members' eligibility before they join the code of conduct.

The supervisory body must establish regular procedures within a clear and defined timeframe to actively and effectively monitor that the members of the code of conduct comply with the provisions of the code.

Guidance

a) A monitoring procedure that defines the method to be applied, i.e., the set of criteria to be assessed, the type of monitoring (self-assessment, remote or on-site audits, recurring checks, use of recognized auditing standards, surveys, etc.), documentation of results, etc.

b) A procedure for investigating, identifying, and managing violations of the code and, where necessary, the corrective actions specified in the code of conduct.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

16(27)

The supervisory body must establish initial, specific, and regular procedures to actively and effectively monitor that the members of the code of conduct comply with the provisions of the code of conduct.

Guidance

Special monitoring may, among other things, be conducted based on an arising situation within the framework of an investigation or as a result of a complaint from a registered individual.

The procedures specified in sections 4.3–4 and the choice between these should be made according to a risk-based approach.

The supervisory body's monitoring procedures must encompass the complete monitoring processes, from the development of an assessment to its conclusion, and they must include additional checks to ensure that appropriate actions are taken to remedy violations and prevent repeated violations.

The procedures for monitoring compliance with codes of conduct must be sufficiently specific to ensure a consistent application of the supervisory body's obligations.

The supervisory body shall establish procedures for regular reviews of the code of conduct's operations. Additional requirements regarding the mechanisms for reviewing the code of conduct are specified in the requirements in section 7.

In establishing the required procedures (for verifying eligibility, monitoring, and review), the supervisory body shall take into account the risk that the processing of personal data within the framework of the code of conduct entails, the expected scope of personal data processing, the number of members of the code of conduct, geographical scope, received complaints, the occurrence of incidents, and other

relevant factors.

The supervisory body and its staff are responsible for the management of all information obtained or created during the monitoring process.

The supervisory body and its staff shall keep confidential all information obtained or created during the course of monitoring, except as required by law or the requirements of this document.

Without affecting Swedish legislation, the supervisory body shall make its decisions regarding concluded monitoring and review procedures available to the public when they concern repeated or serious violations, e.g., those that could lead to the data controller or data processor being suspended or excluded from the code of conduct. Otherwise, the supervisory body shall make publications or summaries of decisions or statistical data regarding its concluded monitoring and review procedures available to the public.

The supervisory body shall demonstrate its assessment of eligibility as well as monitoring and review procedures for IMY during the application process.

Swedish Authority for Privacy Protection

Diary Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

18(27)

5 Open Handling of Complaints

According to Article 41.2 c of the Data Protection Regulation, the supervisory body shall demonstrate the procedures that the body has established to enable it to handle complaints regarding violations of the code of conduct or the manner in which the code of conduct has been implemented or is being implemented by a data controller or processor. These procedures and structures shall be open to registered individuals and the public.

Open and publicly accessible procedures and structures for handling complaints from various sources regarding the members of the code of conduct are an important part of the monitoring of the code of conduct. The requirements below aim to ensure the implementation of an effective complaint handling system.

IMY notes that available complaint procedures should be covered by the code of conduct.

The supervisory body must establish effective and clear procedures and structures for handling complaints.

Guidance

Procedures for handling complaints may be a documented process for receiving, evaluating, tracking, recording, and resolving complaints.

The supervisory body shall include the right of the complainant and the members of the code of conduct to be heard in its procedures.

The supervisory body must make the complaint procedure publicly available and easily accessible.

Guidance on the procedure must be sufficiently clear and understandable for a complainant to comprehend it.

Complaints shall be resolved within a reasonable time. The supervisory body shall establish a timeframe for resolving complaints and make information about the timeframe available to the public. If the complaint cannot be resolved within the estimated timeframe, the supervisory body must inform the complainant of the delay, the reason for it, and a new deadline for resolving the complaint. Complaints that are not complex should normally be resolved within three months.

The supervisory body shall confirm receipt of a complaint within one month.

In the event of a violation of a code of conduct, the supervisory body shall have established procedures for taking immediate action and implementing the corrective measures specified in the code of conduct. The purpose of such procedures must be to interrupt the violation and prevent future recurrence.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

19(27)

The supervisory body shall, without unnecessary delay, inform the complainant, the affected member of the code of conduct, and the owner of the code about the corrective actions taken and their justification. The supervisory body shall also inform IMY and other relevant supervisory authorities. The supervisory body must establish procedures for reopening complaints.

The supervisory body must maintain a register of all complaints received and all actions taken. IMY should be able to access the record at any time.

The supervisory body shall make information about any corrective actions that lead to the suspension or exclusion of members of the code of conduct – and any subsequent revocations of such exclusions – publicly available.

Guidance

Examples of corrective actions include: training, issuing a warning, reporting to a member's board, a formal notice requiring the implementation of specific measures within a specified timeframe, or temporary suspension of the member from the code until corrective actions are taken.

The supervisory body shall publish information about the decisions made within the framework of the complaint handling procedure. The required information may be provided in the form of general statistical data on the number and type of complaints and violations, and the solutions and corrective actions issued.

IMY has the authority to monitor the supervisory body's compliance with Articles 41.1-2 and 41.4 of the Data Protection Regulation, in accordance with Article 57.1 of the Data Protection Regulation. The supervisory body shall therefore establish procedures to inform the complainant about this and forward relevant investigations regarding the supervisory body's monitoring activities to IMY.

The supervisory body shall present its procedures and structures for handling complaints to IMY during the application process.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

20(27)

6 Communication with IMY

The requirements below aim to ensure that the supervisory body's framework enables effective communication to IMY and other competent supervisory authorities regarding the actions taken by the supervisory body concerning the code. This includes information about the suspension or exclusion of members of the code of conduct issued by the supervisory body and any significant changes in the supervisory body. IMY may, based on the information reported to the authority according to sections 6.1 – 6.5 below, initiate a review of the supervisory body's accreditation.

The supervisory body shall establish clear reporting mechanisms to enable written reporting of repeated or serious violations (which would lead to serious reactions from the supervisory body, such as suspension or exclusion from the code) to IMY and other competent supervisory authorities without unnecessary delay. This report shall at least:

- a. notify of the corrective action and provide valid reasons for the decision,
- b. include information about the violation, and
- c. provide information and evidence of the actions taken.

The supervisory body shall be able to provide all relevant information about its actions according to section 6.1 at the request of IMY or other competent supervisory authorities.

The supervisory body shall have a documented procedure for reviewing and lifting a suspension or exclusion of a member from the code of conduct and inform the member, IMY, and other competent supervisory authorities of the outcome of the review.

The supervisory body shall establish reporting mechanisms to enable regular reporting of the results of the supervisory body's reviews of the code of conduct to IMY.

Guidance

Regular reporting may occur through operational, review, or audit reports compiled and presented to IMY annually.

The supervisory body shall, without unnecessary delay, notify IMY of significant changes to the

supervisory body.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

21(27)

Guidance

Significant changes may include the following:

- a) Changes to the supervisory body's legal, commercial, ownership, or organizational status and key personnel.
- b) Changes in resources and locations.
- c) Any changes to the basis for accreditation.
- d) Any other information that is likely to raise questions about the supervisory body's independence, expertise, and lack of conflicts of interest, or that will negatively impact its full functioning.

The supervisory body shall present its reporting mechanisms to IMY during the application process.

Swedish Data Protection Authority

Reference number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

22(27)

7 Mechanisms for Review of Codes

The requirements below aim to ensure that the supervisory body continuously reviews the code in accordance with the review mechanisms described in the code of conduct to ensure that the code remains relevant and continues to contribute to the correct application of the General Data Protection Regulation (GDPR).

It is the responsibility of the owner of the code of conduct to ensure that the code remains relevant and complies with applicable legislation. The supervisory body is not responsible for performing this task, but the body shall contribute to any review of the code of conduct. As a result of a review, the owner of the code of conduct may amend or expand the code.

The supervisory body must contribute to the implementation of reviews of the code of conduct in accordance with the code of conduct.

The supervisory body shall ensure that it has documented plans and procedures for reviewing the functionality of the code of conduct.

In the review of the code of conduct, the supervisory body must assess whether the code is still relevant to the members and continues to contribute to the correct application of the GDPR. Such an assessment should at least take into account any changes in the application and interpretation of the legislation or new technological developments that may affect the processing of personal data carried out by the members or that may affect the provisions of the code of conduct.

The supervisory body shall provide the owner of the code of conduct and the members with an annual report on how the code is functioning. The report shall include the following:

- a. Confirmation that a review of the code of conduct has taken place and information about the supervisory body's results and assessments following the review, as well as whether changes to the code of conduct are required.
- b. Information about personal data incidents among the members of the code of conduct, handled complaints, as well as the type and results of supervisory measures that have been taken. This information may include, but is not limited to, general statistical information about the number and type of personal data incidents, complaints, breaches, and issued solutions and corrective actions.
- c. Confirmation that there are no significant changes in the supervisory body.
- d. Information about new members of the code of conduct.

The supervisory body shall apply updates to the code of conduct according to instructions from the owner of the code of conduct.

Swedish Data Protection Authority

Reference number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

23(27)

The supervisory body shall ensure that information about its conducted reviews and the annual report on the functionality of the code of conduct is documented and made available to IMY upon request. The supervisory body shall present its review procedures to IMY during the application process.

Swedish Data Protection Authority

Reference number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

24(27)

8 Legal Status

The supervisory body may be established or set up in a number of different ways, e.g., as a limited company, association, internal department within the organization of the owner of the code of conduct, or as a natural person. Regardless of the form the supervisory body takes, it must demonstrate that it has an appropriate status to perform its supervisory function and fulfill the responsibilities that follow from this.

The arrangements for the establishment and composition of the supervisory body, its decision-making process, operational rules, and duration, as well as the resources made available to it, shall ensure that the supervisory body can fulfill its supervisory functions and meet the responsibilities that arise from them throughout the duration of the body.

IMY notes that a supervisory body is solely responsible for its function and its tasks under Article 41 of the GDPR. The supervisory body is not responsible for ensuring that the members of the code of conduct comply with the provisions of the GDPR.

The supervisory body must be established within the EEA area.

The supervisory body must be legally accountable, including being liable to pay administrative fines issued in accordance with Article 83.4 c of the GDPR, for its supervisory activities.

During the application process, the code owner must demonstrate that the supervisory body and associated management structures are established, and that it is possible for the supervisory body to take appropriate actions in accordance with Article 41.4 of the GDPR and that it can fulfill the obligations that arise from this.

Guidance

The evidence will depend on the structure of the supervisory body, but may include the following:

- a) Information about the organization and operations, e.g., in relation to the date of establishment, registration number, responsible officials, number of employees, any relationships with other companies and organizations, ownership structures, etc.
- b) Information about relevant resources.
- c) Relevant agreements, arrangements, reference conditions, etc.

During the application process, the supervisory body must confirm to the Swedish supervisory authority that it is responsible for its supervisory role.

Swedish Data Protection Authority

Reference number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

25(27)

The supervisory body must demonstrate that it can implement the monitoring mechanism of the code of conduct during the duration of the supervisory body's mandate, according to section 1.1.3 above. When the supervisory body is a natural person, it must be specifically demonstrated that sufficient resources are available for the natural person to perform the supervisory body's tasks and fulfill its responsibilities. Furthermore, it must be considered and documented how the supervisory role is ensured in the event of departure or temporary incapacity of the person concerned.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

26(27)

9 Subcontractors

The supervisory body may outsource part of its operations to other parties, e.g., in connection with audits. When using subcontractors, the obligations applicable to the supervisory body shall apply equally to the subcontractor. The use of a subcontractor does not relieve the supervisory body of its responsibility. The requirements below aim to ensure that the supervisory body's subcontractor activities are documented and provide sufficient guarantees. The decision-making process may not be outsourced to subcontractors.

If a supervisory body uses subcontractors, the supervisory body must ensure that there are sufficient guarantees regarding the subcontractor's expertise, independence, reliability, and resources, and that the obligations applicable to the supervisory body are also applicable to the subcontractor in the same manner.

Guidance

Point 9.2 can be substantiated with evidence that may include the following:

- a) Agreements with the subcontractor to describe the subcontractor's responsibilities.
- b) Clear procedures for subcontractor contracts must be documented and must include conditions for engaging subcontractors, a procedure for approving subcontractors, and monitoring of subcontractors. The supervisory body shall ensure through regular checks that its subcontractors meet the guarantees according to point 9.2 above.

Guidance

Regular checks may, for example, occur through regular reporting or remote or on-site audits. The supervisory body shall only engage subcontractors that provide sufficient guarantees to implement appropriate technical and organizational measures, in such a way that the processing of personal data within the framework of the supervisory activities complies with the requirements of the General Data Protection Regulation and ensures that the rights of the data subjects are protected.

If a contractual relationship between a supervisory body and a subcontractor ends, or is to end, the supervisory body shall ensure that the subcontractor's supervisory activities are transferred to the supervisory body or to another subcontractor, without interruption in the supervisory activities.

Swedish Authority for Privacy Protection

Case Number: IMY-2022-6945

Appendix – Requirements for Accreditation of Supervisory Bodies

27(27)

The supervisory body shall identify all its subcontractors and provide information to IMY about their details and the role they perform when the supervisory body applies for accreditation. The supervisory body shall provide the same information to IMY if the supervisory body engages a subcontractor after accreditation. IMY shall also be notified if the supervisory body ceases to use any of its subcontractors.